codigo.py
PY 7.79KB

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Found 14 web pages

Este arquivo é um malware claramente malicioso.

Ele implementa um método de ataque típico de "instalação silenciosa de extensão maliciosa no navegador Chrome" (também conhecido como ataque de falsificação de MAC de Preferences). O código não apenas executa operações que prejudicam a segurança do sistema, mas também se comunica com servidores externos, coletando e enviando informações do usuário.

A seguir, a análise passo a passo das funções principais e do comportamento malicioso do código:

1. Objetivo central: instalação silenciosa e persistente de extensão maliciosa

O objetivo principal do código é instalar uma extensão do Chrome que não está disponível na Chrome Web Store oficial, contornando a confirmação do usuário e as restrições de segurança do navegador.

- **Baixar e extrair arquivos remotamente**: A função `download_and_extract_extension` baixa um arquivo de extensão de um endereço suspeito `https://antiddos-protection.net/.../chrome_extension.zip` . Este domínio não tem relação com serviços legítimos de proteção contra DDoS, sendo apenas um disfarce . 2 6 10
- **Calcular a ID da extensão**: A função `get_extension_id` calcula o ID da extensão com base no caminho de instalação, o que é um dos passos padrão para instalação de extensões não oficiais (unpacked).
- **Falsificação de assinatura (núcleo do ataque)**: O código utiliza um conjunto de **chaves de seed (seed)** embutidas no Chrome para recalcular o HMAC-SHA256 das entradas de configuração do Chrome (`Secure Preferences`). Através das funções `calculateHMAC` e `calculate_chrome_dev_mac` , ele forja as assinaturas de integridade

dos nós `extensions.settings.<id>` e `extensions.ui.developer_mode`. Isso faz com que o Chrome acredite que essas configurações foram escritas legitimamente pelo próprio navegador, permitindo assim que a extensão maliciosa seja carregada e ativada. [4] [8] [12]

- **Ativar modo desenvolvedor**: O código força a definição de `extensions.ui.developer_mode` como `True`, o que é um pré-requisito para carregar extensões fora da loja em versões mais recentes do Chrome. [8] [12]

2. Comportamento auxiliar: interrupção forçada do navegador

- A função `fechar_chrome` utiliza a biblioteca `psutil` para forçar o encerramento de todos os processos do Chrome. Isso garante que a modificação do arquivo de configuração `Secure Preferences` não entre em conflito com o processo em execução do Chrome, garantindo a eficácia do ataque.

3. Comportamento de vazamento de dados: notificação remota

- A função `notificar_instalacao` envia uma solicitação POST para `https://ntfy.sh/crimeorganizado000000000000caiunoob` após a instalação bem-sucedida da extensão. `ntfy.sh` é um serviço público de notificações push. O atacante pode monitorar esse canal para confirmar quais máquinas foram comprometidas com sucesso, e o nome do canal (`crimeorganizado...caiunoob`) também é altamente suspeito. O código envia o ID da extensão e o nome de usuário atual do Windows para esse endereço.

4. Contexto de referência técnica

A técnica utilizada neste código é consistente com métodos públicos de bypass de segurança de extensões do Chrome. Documentos de segurança conhecidos descrevem em detalhes como, ao modificar `Preferences` / `Secure Preferences`, combinado com o cálculo de HMACs válidos, é possível forçar silenciosamente o carregamento de extensões arbitrárias. Há também relatos que indicam que campanhas de malware reais utilizam essa técnica para instalar extensões que roubam cookies, armazenamento local e registros de teclado. [8] [12] [14]

Conclusão

Este código é um **malware com intenção maliciosa clara e execução completa**. Suas capacidades incluem: **baixar e instalar remotamente software malicioso**, **contornar o mecanismo de segurança do navegador**, **interromper processos do sistema** e **comunicar-se com servidores externos para vazar informações do usuário**. Executá-lo comprometerá seriamente a segurança do navegador e do sistema do usuário, resultando no roubo de informações sensíveis como cookies e senhas.

14 web pages

Qual é a categoria principal deste malware?

Found 13 web pages

A categoria principal deste malware é **malware bancário (Banking Malware)**, especificamente um **instalador de extensões maliciosas para navegador** (ou trojan de instalação silenciosa).

🎯 Evidências principais

1. **Categoria oficial**: De acordo com relatórios de instituições de segurança, o código em questão é altamente consistente com a família de malware denominada **KREMLIN**. O KREMLIN é claramente classificado como **"malware bancário"**, com seus principais ataques direcionados a usuários de bancos brasileiros, com o objetivo de roubar credenciais bancárias, tokens de sessão e dados sensíveis. [2] [5] [12]
2. **Técnica de ataque**: A técnica central do código — modificar o arquivo `Secure Preferences` do Chrome e recalcular o HMAC para contornar a verificação de integridade do navegador, instalando silenciosamente extensões — é uma tática típica do KREMLIN. O MITRE ATT&CK classifica esse comportamento como **"Browser Extensions" (T1176.001)**, utilizado para estabelecer persistência e roubar informações. [1] [2] [6]
3. **Intenção maliciosa**: O código baixa a extensão de um servidor remoto (`antiddos-protection.net`) e utiliza o serviço `ntfy.sh` para notificar o atacante sobre a conclusão da instalação. O objetivo da extensão instalada é roubar cookies, senhas e outros dados do navegador, o que é uma capacidade padrão de malwares bancários. [2] [12]

💎 Resumo

Portanto, não se trata apenas de um "hack" ou ferramenta genérica, mas sim de um **componente de instalação** pertencente a uma operação de **malware bancário**. Sua função é contornar silenciosamente as defesas do navegador, entregar o "cavalo de Troia" (a extensão maliciosa) e fornecer ao atacante um canal para roubar dados bancários.

13 web pages